

Manual 53 — AI Privacy & Data Governance

Controlled publication source — English

Verification date: 1 September 2026

Release status: candidate source

Purpose

This manual establishes a practical privacy and data-governance operating model for AI systems, including conventional ML, generative AI, RAG/vector stores and agentic systems. It is designed to support enterprise implementation without collapsing jurisdiction-specific legal duties into a single generic privacy rule.

Source-status discipline

NIST Privacy Framework material is voluntary guidance. As of this release, NIST Privacy Framework 1.1 remains an Initial Public Draft project rather than a final replacement for PF 1.0. Jurisdiction-specific laws, regulator guidance and contractual duties retain their own applicability, definitions, rights, timelines and enforcement status. A common enterprise control can support several regimes but does not make those regimes equivalent.

Privacy/data operating model

Use case → data source → authorization/purpose → ingestion → preprocessing → training/fine-tuning → model/provider boundary → prompt/context → RAG/vector store → tools/APIs → output → logs/telemetry → retention/deletion → rights/incident/change evidence.

PD-01 — Authorized data use and purpose limitation

Document the business purpose, lawful or otherwise authorized basis where applicable, source restrictions, compatibility analysis and accountable owner before data is used for training, tuning, RAG, evaluation, monitoring or production inference.

PD-02 — Data inventory, provenance and lineage

Maintain a traceable inventory of datasets, prompts, corpora, embeddings, vector stores, feedback data, evaluation sets and provider-held data. Record source, owner, acquisition basis, transformations, downstream uses and material restrictions.

PD-03 — Data minimization and collection limitation

Limit personal, confidential and sensitive data to what is necessary for the approved purpose. Evaluate whether lower-risk attributes, aggregation, masking, synthetic data or shorter retention can achieve the objective.

PD-04 — Sensitive and special-category data

Identify sensitive, special-category, biometric, health, financial, precise-location, children's and other protected data according to applicable regimes. Apply enhanced authorization, access, minimization, testing and escalation where required.

PD-05 — Data quality and representativeness

Define fitness-for-purpose criteria, known limitations, missingness, sampling bias, label quality and drift. Preserve evidence that data quality decisions were appropriate for the use case and affected populations.

PD-06 — Training and fine-tuning data governance

Control training, fine-tuning and feedback data through approved sourcing, provenance, rights/authorization checks, versioning, integrity, retention and removal procedures. Distinguish provider model-improvement settings from enterprise-controlled training.

PD-07 — RAG and vector-store boundaries

Govern corpus approval, document provenance, embeddings, tenant/role filtering, vector-store access, retrieval policy, stale-source handling and deletion propagation. Retrieval success is not evidence that the underlying source was authorized or accurate.

PD-08 — Retrieval authorization and tenant isolation

Evaluate authorization at retrieval time, not merely at ingestion. Prevent cross-tenant, cross-role and cross-purpose retrieval; test indirect prompt injection and iterative exfiltration paths that could expose data beyond the user's authorization.

PD-09 — Retention and deletion

Define retention rules for source data, prompts, outputs, logs, embeddings, vector stores, caches, backups and provider-held copies. Verify deletion propagation and document technical limitations when immediate deletion is not feasible.

PD-10 — Cross-border transfer and residency

Map origin, processing location, provider/subprocessor chain, storage location and transfer mechanism where applicable. Preserve jurisdiction-specific transfer assessments and safeguards rather than assuming one global control satisfies every regime.

PD-11 — Individual/data-subject rights support

Where applicable, support access, correction, deletion, objection, restriction, appeal or similar rights. Analyze model, training, RAG, log and provider implications and record when a request cannot technically or legally be fulfilled as initially requested.

PD-12 — Transparency and privacy notices

Provide accurate notices about relevant data use, AI processing, provider involvement, retention, automated or AI-supported decisions and material choices where required. Avoid implying that every AI use requires the same notice or consent mechanism.

PD-13 — DPIA/PIA integration

Use privacy impact assessment processes when required or risk-appropriate. Document affected people, necessity/proportionality where applicable, data flows, threats, mitigations, residual risk, consultation needs, approvals and reassessment triggers.

PD-14 — AI impact/risk assessment integration

Share evidence between privacy and AI-risk assessments while preserving separate decision criteria. Link privacy harms, fairness concerns, security threats, human oversight, explainability and operational impacts without treating one assessment as a substitute for another.

PD-15 — De-identification and re-identification risk

Validate anonymization, de-identification, pseudonymization or aggregation claims against realistic linkage and inference risks. Do not treat transformed data as automatically outside privacy scope without a supportable legal and technical analysis.

PD-16 — Privacy-preserving logging and observability

Collect enough telemetry for security, quality and accountability while minimizing unnecessary personal or sensitive content. Define redaction, access, retention, correlation identifiers and incident-preservation rules.

PD-17 — Third-party/model-provider data governance

Assess provider roles, prompt/output use, model-improvement settings, subprocessors, hosting, retention, security, incident duties, audit evidence, transfer conditions and exit/deletion requirements. Contractual statements must be reconciled with actual technical configuration.

PD-18 — Privacy incident and breach response

Preserve affected data, people, systems, model/provider versions, prompts, retrieval events, identities and containment evidence. Perform jurisdiction-specific notification analysis and integrate privacy incidents with enterprise security and AI incident response.

PD-19 — Change management and reassessment

Trigger reassessment for new data sources, purposes, jurisdictions, model/provider versions, RAG corpora, tools, permissions, retention settings or material processing changes. Record approval, testing and residual-risk disposition.

PD-20 — Assurance, audit and management reporting

Test implementation evidence, rights workflows, deletion, retrieval boundaries, provider controls, assessment quality and exceptions. Report material residual risks, overdue remediation, incidents, transfer issues and recurring control failures to accountable management.

Scenario pack

Scenario 1 — Global GenAI assistant with internal RAG

Trace document provenance, employee/customer data sensitivity, access boundaries, embedding/vector retention, provider training-use restrictions, cross-border hosting, deletion propagation and retrieval logs. Separate common governance evidence from jurisdiction-specific obligations.

Scenario 2 — Model trained on historical customer data

Validate original purpose, authorization, minimization, sensitive-data handling, retention, representativeness, de-identification claims and downstream risks. Determine whether retraining, exclusion or deletion is technically and legally required after source withdrawal or rights requests.

Scenario 3 — AI-supported employment decision

Combine privacy/employment-law analysis, AI impact assessment, data minimization, sensitive or inferred attributes, human review, explanation/appeal support, retention and vendor accountability.

Scenario 4 — External foundation-model provider

Document provider role analysis where applicable, prompt/output use, subprocessors, hosting, retention, security, incidents, model-improvement settings and exit/deletion requirements.

Scenario 5 — New jurisdiction added after deployment

Trigger applicability review, transfer analysis, notices/rights analysis, local retention requirements, provider-location review and reapproval before broadening deployment where required.

Evidence register

- PD-E01 AI data inventory.
- PD-E02 Data provenance and lineage record.
- PD-E03 Authorized-use/purpose assessment.
- PD-E04 DPIA/PIA and AI impact assessment evidence.
- PD-E05 Sensitive-data control record.
- PD-E06 RAG/vector governance record.
- PD-E07 Rights-response evidence.
- PD-E08 Cross-border transfer assessment.
- PD-E09 Third-party data assessment.
- PD-E10 Retention/deletion verification.
- PD-E11 Privacy incident record.
- PD-E12 Change/revalidation record.

Release rule

A privacy control is not effective merely because policy text exists. Effectiveness requires implementation evidence, jurisdiction-qualified applicability, testing, exception handling and residual-risk disposition. Material legal, provider or technical changes trigger re-evaluation.